

ЗАТВЕРДЖЕНО
Наказ Держспецзв'язок України
_____ 2026 року № _____

Базовий профіль безпеки системи, де обробляється службова інформація, затверджений
наказом Адміністрації Держспецзв'язку від 02.07.2025 № 419

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
УПРАВЛІННЯ ДОСТУПОМ (АС)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
1	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)	Визначено передумови та критерії членства в групах і ролях; визначено атрибути (за необхідності) для кожного облікового запису; визначено персонал або ролі, необхідні для затвердження запитів на створення облікових записів; визначено політику, процедури, передумови та критерії створення, активації, зміни, деактивації та видалення облікових записів; визначено персонал або ролі, які мають бути повідомлені; визначено період часу, протягом якого адміністратори облікових записів повинні бути повідомлені про те, що облікові записи більше не потрібні; визначено термін, протягом якого необхідно повідомляти адміністраторів облікових записів про звільнення або переведення користувачів; визначено період часу, протягом якого необхідно повідомляти адміністраторів облікових записів про зміни у використанні системи або необхідність знати про зміни для окремої особи; визначено атрибути, необхідні для авторизації доступу до системи (за потреби); АС-02_ODP[10] АС-02a.[01] АС-02a.[02] АС-02b АС-02c АС-02d.01 АС-02d.02 АС-02d.03[01] АС-02d.03[02] АС-02e АС-02f.[01] АС-02f.[02] АС-02f.[03] АС-02f.[04] АС-02f.[05] АС-02g АС-02h.01 АС-02h.02 АС-02h.03 АС-02i.01 АС-02i.02 АС-02i.03 визначено періодичність перегляду облікових записів; визначено та задокументовано типи облікових записів, дозволених для використання в системі; визначено та задокументовано типи облікових записів, які заборонено використовувати в системі; призначені менеджери облікових записів; необхідні умови та критерії для членства в групах та ролях; визначено авторизованих користувачів системи; вказано приналежність до групи або ролі; для кожного облікового запису вказуються повноваження доступу (тобто привілеї); атрибути (за необхідності) вказуються для кожного облікового запису; для запитів на створення облікових записів потрібні схвалення від персоналу або ролей; облікові записи створюються відповідно до політики, процедур, передумов та критеріїв; облікові записи активуються відповідно до політики, процедур, передумов та критеріїв; облікові записи змінюються відповідно до політики, процедур, передумов та критеріїв; облікові записи деактивуються відповідно до політики, процедур, передумов та критеріїв; облікові записи видаляються відповідно до політики, процедур, передумов та критеріїв; контролюється використання облікових записів; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли облікові записи більше не потрібні; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли користувачі звільнені чи переведені; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. доступ до системи здійснюється на підставі дійсної авторизації доступу; доступ до системи авторизується на основі передбачуваного використання системи; доступ до системи авторизовано на основі атрибутів (за необхідності); АС-02j АС-02k.[01] АС-02k.[02] АС-02l.[01]	АС-2	24

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Облікові записи деактивуються протягом часового періоду, коли облікові записи більше не пов'язані з користувачем або фізичною особою Облікові записи відключено протягом часового періоду, коли облікові записи порушують політику організації; облікові записи деактивуються протягом , якщо вони були неактивними протягом Визначено період часу, протягом якого необхідно деактивувати облікові записи Визначено період часу неактивності, після закінчення якого облікові записи будуть деактивовані; AC-02(03)(a) облікові записи деактивуються протягом часового періоду, коли термін дії облікових записів минув	AC-2(3)	admin, security_officer default_deny_rule, abac_rule_1 30 login, logout, failed_attempt
		Користувачі повинні виходити з системи, коли період очікуваної бездіяльності або опис часу, коли потрібно вийти з системи Визначено часовий період очікуваної бездіяльності або опис, коли потрібно вийти з системи	AC-2(5)	30 30
		Облікові записи користувачів деактивуються протягом періоду часу з моменту виявлення значних ризиків Визначено період часу, протягом якого необхідно деактивувати облікові записи фізичних осіб, які становлять значний ризик	AC-2(13)	30 30
2	ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (AC-3)	Затверджені повноваження на логічний доступ до інформації та ресурсів системи виконуються відповідно до чинних політик(правил) управління доступом	AC-3	default_deny_rule, abac_rule_1
3	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (AC-4)	Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками Визначено політики управління інформаційними потоками всередині системи та між підключеними системами	AC-4	default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1
4	РОЗМЕЖУВАННЯ ОБОВ'ЯЗКІВ (AC-5)		AC-5	
5	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (AC-6)		AC-6	
		Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки	AC-6(1)	admin, security_officer
		Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень Визначено частоту перегляду повноважень, призначених ролям або класам користувачів Визначено ролі або класи користувачів, яким призначено повноваження	AC-6(7)	30 30 admin, security_officer
			AU-9(4)	
6	НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (AC-6(2)) (AC-6)	Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій	AC-6(2)	admin, security_officer
		Привілейовані облікові записи в системі обмежено персонал або ролі Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі	AC-6(5)	admin, security_officer admin, security_officer
7	АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (AC-6(9)) (AC-6)		AC-6(9)	
			AC-6(10)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
8	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)	Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію} Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано) Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано) Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано)	АС-7	30 30 30 AES-256-GCM 30 AES-256-GCM 3
9	ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)	Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням подальшого доступу до загальнодоступної системи; для загальнодоступних систем відображаються будь-які посилання на моніторинг, запис або аудит, які узгоджуються з положеннями про конфіденційність таких систем, що зазвичай забороняють ці види діяльності; для загальнодоступних систем додається опис авторизованого використання системи	АС-8	default_deny_rule, abac_rule_1

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
10	БЛОКУВАННЯ ПРИСТРОЮ (АС-11)	Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ініціювання блокування пристрою після періоду неактивності; вимога до користувача ініціювати блокування пристрою перед тим, як залишити систему без нагляду} Часовий проміжок бездіяльності, після якого ініціюється блокування пристрою (якщо вибрано)	АС-11	30 30
			АС-11(1)	
11	ПРИПИНЕННЯ СЕАНСУ (АС-12)	Визначено умови або події, що вимагають припинення сеансу	АС-12	login, logout, failed_attempt
12	ВІДДАЛЕНИЙ ДОСТУП (АС-17)		АС-17	
			АС-17(3)	
			АС-17(4)	
13	БЕЗДРОТОВИЙ ДОСТУП (АС-18)		АС-18	
		Бездротовий доступ до системи захищений за допомогою шифрування	АС-18(1)	AES-256-GCM
			АС-18(3)	
14	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)		АС-19	
			АС-19(5)	
15	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)	Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту} Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано)	АС-20	
		Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планах безпеки та конфіденційності (якщо такі застосовуються) Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система	АС-20(1)	admin, security_officer admin, security_officer
		Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах	АС-20(2)	admin, security_officer admin, security_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
16	ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)	Визначені особи уповноважені на розміщення інформації в загальнодоступній системі Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою Визначено частоту, з якою слід переглядати зміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом	АС-22	admin, security_officer admin, security_officer 30 30
ОБІЗНАНІСТЬ ТА НАВЧАННЯ (АТ)				
17	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)	Оновлюється зміст навчання грамотності та підвищення обізнаності з частотою Визначено періодичність проведення навчання грамотності з питань безпеки для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу Визначено періодичність проведення навчання грамотності з питань конфіденційності для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу Визначено події, які потребують навчання користувачів системи грамотності з питань безпеки Визначено частоту оновлення навчання грамотності та змісту обізнаності; АТ-02_ ODP[07] визначено події після яких необхідне оновлення навчання грамотності та змісту обізнаності; АТ-02(а)[01][01] навчання з грамотності з питань безпеки надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(а)[01][02] навчання з грамотності з питань конфіденційності надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(а)[01][03] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з безпеки з періодичністю після цього; АТ-02(а)[01][04] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з конфіденційності з періодичністю після цього; АТ-02(а)[02][01] тренінги з грамотності з питань безпеки проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій; АТ-02(а)[02][02] тренінги з грамотності з питань конфіденційності проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій Визначено події, які потребують навчання користувачів системи грамотності з питань конфіденційності	АТ-2	30 щорічно щорічно login, logout, failed_attempt login, logout, failed_attempt
			АТ-2(2)	
			АТ-2(3)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
18	РОЛЬОВЕ НАВЧАННЯ (АТ-3)	Оновлюється вміст навчання на основі ролей з частотою Визначено ролі та обов'язки для тренінгів з безпеки на основі ролей Визначено ролі та обов'язки для тренінгів з конфіденційності на основі ролей Визначено частоту проведення тренінгів на основі ролей з безпеки та конфіденційності для призначеного персоналу після початкової підготовки Визначено частоту оновлення змісту навчання на основі ролей Визначено події, які потребують оновлення змісту навчання на основі ролей; АТ-03(а)[01][01] навчання з безпеки на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; АТ-03(а)[01][02] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; АТ-03(а)[01][03] навчання з безпеки на основі ролей проводиться для ролей та обов'язків з частотою після цього; АТ-03(а)[01][04] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків з частотою після цього; АТ-03(а)[02][01] навчання з питань безпеки на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі; АТ-03(а)[02][02] навчання з питань конфіденційності на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі	АТ-3	30 admin, security_officer admin, security_officer admin, security_officer 30 admin, security_officer
АУДИТ ТА ПІДЗВІТНІСТЬ (АУ)				
19	ПОДІЇ АУДИТУ (АУ-2)	Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <АУ-Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота. у системі Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події Частота перегляду та оновлення типів подій, обраних для журналювання	АУ-2	щорічно щорічно login, logout, failed_attempt щорічно
20	ЗМІСТ ЗАПИСІВ АУДИТУ (АУ-3)	Записи аудиту містять інформацію, яка встановлює який тип події стався Записи аудиту містять інформацію, яка встановлює джерело події Записи аудиту містять інформацію, яка встановлює наслідки події Записи аудиту містять інформацію, яка встановлює результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією	АУ-3	login, logout, failed_attempt login, logout, failed_attempt login, logout, failed_attempt login, logout, failed_attempt
21	ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (АУ-11)	Записи аудиту зберігаються впродовж період часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів	АУ-3(1) АУ-11	30 default_deny_rule, abac_rule_1

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Персонал або ролі може/можуть вибирати типи подій, які будуть реєструватися певними компонентами системи; AU-12(c) згенеровано записи аудиту для типів подій, визначених у AU02_ODP[02], які включають вміст записів аудиту, визначений у AU03 Визначено персонал або ролі, яким дозволено обирати типи подій, що мають реєструватися певними компонентами системи	AU-12	admin, security_officer admin, security_officer
22	РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)	Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу Додаткові дії виконуються у разі збою процесу обробки даних аудиту Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту	AU-5	admin, security_officer login, logout, failed_attempt admin, security_officer admin, security_officer login, logout, failed_attempt
23	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)	Записи аудиту системи переглядаються та аналізуються частота для виявлення ознак неналежної або незвичної діяльності та потенційного впливу неналежної або незвичної діяльності Звіт аудиту відправляється персоналу або ролям Визначено частоту, з якою переглядаються та аналізуються записи аудиту системи Визначено персонал або ролі які отримують результати оглядів та аналізів системних записів	AU-6	щотижня admin, security_officer 30 admin, security_officer
			AU-6(3)	
24	СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)	Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту	AU-7	30 30
25	ПОЗНАЧКА ЧАСУ (AU-8)	Внутрішній системний годинник використовується для створення позначок часу для записів аудиту Позначки часу застосовуються для записів аудиту, які відповідають деталізації вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеве зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу Визначено деталізацію вимірювання часу для часових позначок записів аудиту	AU-8	30 30 30
26	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)	Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту	AU-9	admin, security_officer admin, security_officer
			AU-9(4)	
УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (CM)				
27	БАЗОВА КОНФІГУРАЦІЯ (CM-2)	Переглядаються та оновлюються базові налаштування системи частота Визначено частоту налаштувань; перегляду та оновлення базових	CM-2	щорічно 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
28	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)	Зміни в налаштуваннях конфігурації відстежуються відповідно до політики та процедур організації Зміни налаштувань конфігурації керуються відповідно до політики та процедур організації	СМ-6	default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1
29	УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)	Записи про зміни конфігурації у системі зберігаються протягом <період часу СМ-03_ODP[01]> Визначено період часу, протягом якого зберігатимуться записи про зміни конфігурації Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли умови} Визначено частоту, з якою викликаються елементи управління змінами конфігурації (якщо вибрано) Визначено умови, за яких викликаються елементи управління змінами конфігурації (якщо вибрано); СМ-03(а) визначено та задокументовано типи змін до системи, які контролюються конфігурацією	СМ-3	30 30 30
30	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)		СМ-4	
			СМ-4(2)	
31	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)		СМ-5	
32	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7)	Використання протоколи заборонено або обмежено Визначено протоколи, які необхідно заборонити або обмежити; СМ-07_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити	СМ-7	TLS 1.3 TLS 1.3
		Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними	СМ-7(1)	TLS 1.3 TLS 1.3 TLS 1.3 TLS 1.3
33	АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5)) (СМ-7)	Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі Переглядається та оновлюється список авторизованих програм частота Визначено частоту перегляду та оновлення списку авторизованих програм	СМ-7(5)	default_deny_rule, abac_rule_1 30
34	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)	Переглядається та оновлюється опис компонентів системи частота Визначено частоту перегляду та оновлення опису компонентів системи	СМ-8	щорічно 30
			СМ-8(1)	
35	РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)		СМ-12	
36	КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7)) (СМ-2)	Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком	СМ-2(7)	admin, security_officer admin, security_officer admin, security_officer
ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (ІА)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
37	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (IA-2)		IA-2	
			IA-11	
38	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (IA-3)		IA-3	
39	БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (IA-2(1)) (IA-2)		IA-2(1)	
			IA-2(2)	
40	ДОСТУП ДО ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ (IA-2(8)) (IA-2)		IA-2(8)	
41	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)	Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора Визначено період часу для запобігання повторному використанню ідентифікаторів	IA-4	admin, security_officer admin, security_officer admin, security_officer 30
			IA-4(4)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
42	АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1)) (IA-5)	Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальновживаних, очікуваних або скомпрометованих паролів в IA-05(01)(а) Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму гешування, переважно використовуючи ключову геш-функцію Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів Для автентифікації на основі пароля застосовуються склад та правила складності Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів Визначено склад та правила складності автентифікатора	IA-5(1)	admin, security_officer admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1
43	ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА (IA-6)	Забезпечено приховану зворотну передачу інформації автентифікації в про- цесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами	IA-6	admin, security_officer
44	АВТЕНТИФІКАТОР УПРАВЛІННЯ (IA-5)	Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора	IA-5	admin, security_officer login, logout, failed_attempt 30
РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR)				
45	ОБРОБКА ІНЦИДЕНТУ (IR-4)		IR-4	
46	МОНІТОРИНГ ІНЦИДЕНТУ (IR-5)		IR-5	
		Персонал зобов'язаний повідомляти про підозрілі інциденти протягом періоду часу Визначено період часу, протягом якого персонал повинен повідомляти про підозрілі інциденти до уповноваженого органу	IR-6	admin, security_officer admin, security_officer
			IR-7	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
47	ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)	Ефективність реагування системи на інциденти перевіряється частота за допомогою тестів Визначено частоту, з якою необхідно перевіряти ефективність реагування системи на інциденти	IR-3	щорічно 30
48	НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)	Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе ролі або обов'язків з реагування на інциденти або отримання доступу до системи Користувачам системи надається навчання з реагування на інциденти відповідно до призначених ролей та обов'язків частота Зміст навчання з реагування на інциденти переглядається та оновлюється частота Визначено частоту, з якою користувачі повинні проходити навчання з реагування на інциденти Визначено частоту перегляду та оновлення змісту навчання з реагування на інциденти Визначено події, які ініціюють перегляд змісту навчання з реагування на інциденти	IR-2	admin, security_officer щорічно щорічно 30 login, logout, failed_attempt
49	ПЛАН РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-8)	Розроблено план реагування на інцидент, який розглядається та затверджується персоналом або ролями частота Розроблено план реагування на інциденти, в якому чітко визначено відповідальність за реагування на інциденти для організацій, персоналу або ролей Копії плану реагування на інцидент розповсюджуються серед <IR- 08 _ODP[04] персоналу з реагування на інциденти> План реагування на інциденти оновлюється з урахуванням змін у системі та організації або проблем, що виникають під час впровадження, виконання або тестування плану Зміни в плані реагування на інцидент повідомляються персоналу з реагування на інциденти Визначено персонал або ролі, які переглядають та затверджують план реагування на інциденти Визначено періодичність перегляду та затвердження плану реагування на інциденти Визначені організації, персонал або ролі, які несуть відповідальність за реагування на інциденти; IR-08 _ODP[04] визначено персонал з реагування на інцидент (ідентифікований за іменами та/або за ролями), якому мають бути роздані копії плану реагування на інцидент Визначено персонал з реагування на інцидент (ідентифікований за іменами та/або ролями), якому повідомляються зміни до плану реагування на інцидент	IR-8	admin, security_officer admin, security_officer admin, security_officer 30 admin, security_officer admin, security_officer щорічно admin, security_officer admin, security_officer
ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ (МА)				
50	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)	Переглядаються раніше затверджені інструменти технічного обслуговування частота Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування	МА-3	щорічно 30
		Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій	МА-3(1)	admin, security_officer
			МА-3(2)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі. Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту.	МА-3(3)	admin, security_officer admin, security_officer
51	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)	Впроваджено віддалені дії з обслуговування та діагностики. Відстежуються віддалені дії з обслуговування та діагностики. Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації.	МА-4	login, logout, failed_attempt login, logout, failed_attempt default_deny_rule, abac_rule_1
52	ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)	Запроваджено процес авторизації технічного персоналу. Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування. Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ. Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ.	МА-5	admin, security_officer admin, security_officer admin, security_officer admin, security_officer
ЗАХИСТ НОСІВ ІНФОРМАЦІЇ (МР)				
53	ЗБЕРІГАННЯ НОСІВ ІНФОРМАЦІЇ (МР-4)		МР-4	
54	ДОСТУП ДО НОСІВ ІНФОРМАЦІЇ (МР-2)	Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей. Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей. Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації. Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації.	МР-2	admin, security_officer admin, security_officer admin, security_officer admin, security_officer
55	ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (МР-6)	Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації.	МР-6	автоматизований засіб моніторингу
56	МАРКУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-3)	Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах.	МР-3	30
57	ТРАНСПОРТУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-5)	Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки. Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки. Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи. Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації. Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом. Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон.	МР-5	30 30 30 admin, security_officer admin, security_officer 30
			SC-28	
58	ВИКОРИСТАННЯ НОСІВ ІНФОРМАЦІЇ (МР-7)		МР-7	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (CP)				
59	РЕЗЕРВНЕ КОПІЮВАННЯ (CP-9)	Резервне копіювання інформації користувача, що міститься в компонентах системи, здійснюється частота Виконується резервне копіювання інформації системи, що міститься в системі частота; CP-09(с) створюються резервні копії документації системи, включаючи документацію, пов'язану з безпекою та конфіденційністю частота Визначено частоту, з якою слід проводити резервне копіювання інформації користувача відповідно до часу відновлення та цілей відновлення Визначено частоту проведення резервного копіювання інформації системи, що відповідає завдань відновлення і встановлених цілей відновлення Визначено частоту, з якою слід проводити резервне копіювання документації системи відповідно до часу відновлення та цілей точки відновлення	CP-9	щорічно щорічно 30 30 30
		Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації	CP-9(8)	AES-256-GCM
БЕЗПЕКА ПЕРСОНАЛУ (PS)				
60	ПЕРЕВІРКА ПЕРСОНАЛУ (PS-3)	Визначені умови, що вимагають повторної перевірки осіб Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота	PS-3	admin, security_officer
61	ЗВІЛЬНЕННЯ ПЕРСОНАЛУ (PS-4)	Визначено період часу, протягом якого забороняється доступ до системи Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин	PS-4	30 admin, security_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Визначені дії, які мають бути ініційовані після переведення або перепризначення Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або ролі протягом часового періоду	PS-5	login, logout, failed_attempt login, logout, failed_attempt admin, security_officer admin, security_officer
ФІЗИЧНИЙ ЗАХИСТ ТА ЗАХИСТ НАВКОЛИШНЬОГО СЕРЕДОВИЩА (PE)				
62	РЕ-2 ДОСТУПУ (РЕ-2)	Розроблено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система Затверджено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система Ведеться перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система Переглядається список доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта частота Особи видаляються зі списку доступу до об'єкта, коли доступ більше не потрібен Визначено періодичність перегляду списку доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта	РЕ-2	admin, security_officer admin, security_officer admin, security_officer
63	МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ (РЕ-6)	Переглядаються журнали фізичного доступу частота Визначено частоту перегляду журналів фізичного доступу Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу	РЕ-6	щорічно 30 login, logout, failed_attempt
64	АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (РЕ-17)	Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; РЕ-17(a) альтернативні робочі місця визначені та задокументовані; РЕ-17(b) заходи захисту впроваджені на альтернативних робочих місцях; РЕ-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; РЕ-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів	РЕ-17	admin, security_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
65	ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ (РЕ-3)	Активність відвідувачів контролюється умови Пристрої фізичного доступу інвентаризуються частота Коди доступу змінюється частота, коли код скомпрометовано, або коли особи, які володіють кодом, переводяться або звільняються; <РЕ- РЕ-03(g)[02] ключі змінюються частота, коли ключі втрачено, або коли особи, що володіють ключами, переводяться або звільняються Визначено умови, що вимагають супроводу відвідувачів та моніторингу активності відвідувачів Визначено частоту проведення інвентаризації пристроїв фізичного доступу Визначено частоту, з якою потрібно змінювати коди доступу Визначено частоту, з якою потрібно змінювати ключі	РЕ-3	щорічно admin, security_officer 30 30 30
66	РЕ-4 ЛІНІЙ ЕЛЕКТРОЖИВЛЕННЯ (РЕ-4)		РЕ-5 РЕ-4	
ОЦІНКА РИЗИКІВ (RA)				
67	ОЦІНЮВАННЯ РИЗИКУ (RA-3)	Визначено періодичність оцінювання ризику Визначено персонал або ролі, до яких мають бути доведені результати оцінювання ризику Визначена періодичність оновлення оцінювання ризику; перегляду результатів RA-03a.01 проводиться оцінювання ризику для виявлення загроз і вразливостей у системі; RA-03a.02 проводиться оцінювання ризику для визначення ймовірності та розміру шкоди від несанкціонованого доступу, використання, розкриття, порушення, модифікації або знищення системи; інформації, яку вона обробляє, зберігає або передає; а також будь-якої пов'язаної з нею інформації; RA-03a.03 проводиться оцінювання ризику для визначення ймовірності та впливу несприятливих наслідків для фізичних осіб, що виникають у зв'язку з обробкою інформації, яка ідентифікує особу; RA-03b. інтегровані результати оцінювання ризику та рішення з управління ризиками з точки зору організації та місці або бізнес-процесів з оцінкою ризиків на системному рівні; RA-03c. результати оцінювання ризику задокументовані в ЗНАЧЕННЯ ВИБРАНОВОГО ПАРАМЕТРА; RA-03d. переглядаються результати 03_ODP[03] частота>; RA-03e. поширюються результати оцінювання ризику серед персоналу або ролей; RA-03f. оновлюється оцінювання ризику частота або коли відбуваються значні зміни в системі, середовищі її функціонування або інших умовах, які можуть вплинути на стан безпеки або приватності системи оцінювання ризику <RA-	RA-3	щорічно admin, security_officer admin, security_officer
			RA-3(1)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Оцінюються та аналізуються ризики, пов'язані з ланцюгом постачання, які стосуються постачальників або підрядників та систем, компонентів системи або системних послуг, які вони надають < SR-06 _ ODP частота > Визначена періодичність оцінки та аналізу ризиків, пов'язаних з ланцюгом постачання, що стосуються постачальників або підрядників, а також систем, компонентів системи або системних послуг, які вони надають	SR-6	щорічно щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
68	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)	Визначена періодичність перевірки систем та розміщених на них застосунків на наявність вразливостей Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику Потрібно ділитися інформацією, отриманою в процесі сканування вразливостей та оцінок контролю, з персоналом або ролями, з якими потрібно ділитися; RA-05a.[01] здійснюється моніторинг систем та розміщених застосунків на наявність вразливостей частота та/або випадковість відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05a.[02] перевіряються системи та розміщені застосунки на наявність вразливостей частота та/або випадковим чином відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05b. застосовуються інструменти та методи моніторингу вразливостей для забезпечення сумісності між інструментами; RA-05b.01 застосовуються інструменти та методи моніторингу вразливостей для автоматизації частини процесу управління вразливостями, використовуючи стандарти для переліку платформ, недоліків програмного забезпечення та неправильних конфігурацій; RA-05b.02 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для формування контрольних списків та процедур тестування; RA-05b.03 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частин процесу управління вразливостями шляхом використання стандартів для вимірювання впливу вразливостей; RA-05c. аналізуються звіти про сканування вразливостей та результати моніторингу вразливостей; RA-05d. усуваються легітимні вразливості час реагування відповідно до організаційної оцінки ризиків; RA-05e. надається інформація, отримана в процесі моніторингу вразливостей та оцінки контролю, персонал або ролі, щоб допомогти усунути подібні вразливості в інших системах; RA-05f. використовуються інструменти моніторингу вразливостей, які передбачають можливість швидкого оновлення вразливостей, що підлягають скануванню	RA-5	щорічно 30 admin, security_officer
		Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику	RA-5(2)	30
69	РЕАГУВАННЯ НА РИЗИК (RA-7)		RA-7	
ОЦІНЮВАННЯ, АВТОРИЗАЦІЯ ТА МОНІТОРИНГ (CA)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
70	ОЦІНЮВАННЯ (CA-2)	Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. CA-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання План оцінки заходів захисту розглядається та затверджується уповноваженою посадовою особою або призначеним представником перед проведенням оцінки Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до безпеки Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до конфіденційності; CA-02(e) готується звіт оцінювання Результати оцінювання з безпеки надаються особам або ролям. оцінювання , який документує результати Визначено частоту, з якою слід оцінювати засоби контролю в системі та середовищі її функціонування Визначені особи або ролі, яким мають бути надані результати оцінювання з безпеки	CA-2	admin, security_officer admin, security_officer admin, security_officer щорічно щорічно admin, security_officer 30 admin, security_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
71	ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (CA-5)	Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі Існуючий план оновлюється частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу	CA-5	login, logout, failed_attempt щорічно 30
72	БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (CA-7)	Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота Визначено частоту, з якою слід моніторити ефективність заходів захисту Визначено частоту, з якою слід оцінювати ефективність заходів захисту Визначено персонал або ролі, яким повідомляється про стан безпеки системи Визначено частоту, з якою повідомляється про стан безпеки системи Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи Визначено частоту, з якою повідомляється про стан конфіденційності системи	CA-7	30 30 login, logout, failed_attempt admin, security_officer admin, security_officer 30 30 admin, security_officer 30 admin, security_officer 30
73	ВЗАЄМОДІЯ СИСТЕМ (CA-3)	Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін Вимоги до безпеки задокументовані як частина кожної угоди про обмін Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін Заходи захисту задокументовані як частина кожної угоди про обмін Відповідальність за кожну систему задокументована як частина кожної угоди про обмін Характер переданої інформації документується як частина кожної угоди про обмін Угоди переглядаються та оновлюються частота Визначено частоту, з якою необхідно переглядати та оновлювати угоди	CA-3	30 30 30 30 30 30 щорічно 30
ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC)				
74	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)		SC-7	
75	ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)		SC-4	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
76	ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5)) (SC-7)		SC-7(5)	
77	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)		SC-8	
			SC-8(1)	
			SC-28	
		Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях	SC-28(1)	AES-256-GCM AES-256-GCM
78	ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)	Визначено період бездіяльності, після якого система розриває мережеве з'єднання, пов'язане з сеансом зв'язку; SC08(05)_ ODP[02] мережеве з'єднання, пов'язане з сеансом зв'язку, розірвано в кінці сеансу або після період часу бездіяльності	SC-10	30
79	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ ODP вимог > Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог	SC-12	AES-256-GCM AES-256-GCM
80	КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)	КРИПТОГРАФІЧНИЙ ЗАХИСТ МЕТА ОЦІНКИ: Визначити, чи: Визначено використання криптографічних засобів Визначено типи криптографії для кожного вказаного криптографічного використання; SC-13a. ідентифіковано використання>; SC-13b. реалізовано типи криптографії для кожного вказаного криптографічного використання (визначеного в SC-13_ ODP[01]). криптографічне <SC-13_ ODP[01]	SC-13	AES-256-GCM AES-256-GCM AES-256-GCM
81	СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)		SC-15	
82	МОБІЛЬНИЙ КОД (SC-18)		SC-18	
83	АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)		SC-23	
ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
84	ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)	Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією	SI-2	30
85	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)	Визначено частоту, з якою механізми шкідливого коду виконують сканування Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано)	SI-3	30 login, logout, failed_attempt
86	ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)	Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації} Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено)	SI-5	admin, security_officer admin, security_officer
87	МОНІТОРИНГ СИСТЕМИ (SI-4)	Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота}	SI-4	admin, security_officer admin, security_officer admin, security_officer щорічно
		Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку Здійснюється моніторинг вхідного комунікаційного трафіку частота на предмет незвичних або несанкціонованих дій або умов Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення	SI-4(4)	щорічно щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
88	УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)	Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог	SI-12	default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1
Політики та процедури з безпеки				
89	Політики та процедури з безпеки	Визначено персонал або ролі, на які поширюється політика контролю доступу Визначено персонал або ролі, на які поширюються процедури контролю доступу Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу	AC-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30
			AT-1	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику аудиту та підзвітності Політика аудиту та підзвітності доведена до персонал або ролі Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частота; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частота; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після подій Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності Визначено персонал або ролі, на які поширюються процедури аудиту та підзвітності Визначено посадову особу, яка управлятиме політикою та процедурами аудиту та підзвітності Визначено частоту, з якою переглядається та оновлюється поточна політика аудиту та підзвітності Визначено події, які потребують перегляду та оновлення поточної політики аудиту та підзвітності Визначено частоту, з якою переглядаються та оновлюються поточні процедури аудиту та підзвітності Визначено події, які потребують перегляду та оновлення поточної процедури аудиту та підзвітності	AU-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику оцінювання, авторизації та моніторингу Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; CA-01(c)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; CA-01(c)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу після подій; CA-01(c)[02][01] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу з частотою; CA-01(c)[02][02] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу після подій; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ: Визначено персонал або ролі, серед яких має бути поширена політика оцінювання, авторизації та моніторингу Визначено персонал або ролі, серед яких мають бути поширені процедури оцінювання, авторизації та моніторингу Визначено посадову особу, яка управлятиме розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу Визначено частоту, з якою переглядається та оновлюється поточна політика оцінювання, авторизації та моніторингу Визначено події, які потребують перегляду та оновлення поточної політики оцінки, авторизації та моніторингу Визначено частоту, з якою переглядається та оновлюється поточні процедури оцінювання, авторизації та моніторингу Визначено події, які потребують перегляду та оновлення поточні процедури оцінки, авторизації та моніторингу	CA-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику управління конфігурацією Політика управління конфігурацією поширюється на персонал або ролі Розроблені та задокументовані процедури управління , що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; СМ-01(с)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; СМ-01(с)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; СМ-01(с)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота; СМ-01(с)[02][02] переглядаються та оновлюються поточні процедури управління конфігурацією після події; ЗНАЧЕННЯ конфігурацією Визначено персонал або ролі, на яких поширюється політика управління конфігурацією Визначено персонал або ролі, на яких поширюється процедури управління конфігурацією Визначено посадову особу, яка управляє розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією Визначено частоту, з якою переглядається та оновлюється поточна політика управління конфігурацією Визначено події, після яких переглядається та оновлюється поточна політика управління конфігурацією Визначено частоту, з якою переглядаються та оновлюються поточні процедури управління конфігурацією Визначено події, після яких переглядаються та оновлюються поточні процедури управління конфігурацією	СМ-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику ідентифікації та автентифікації Політика ідентифікації та автентифікації поширюється на персонал або ролі Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації; IA-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота; IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій; IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації частота; IA-01(c)[02][02] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації після подій Визначено персонал або ролі, на які поширюється політика ідентифікації та автентифікації Визначено персонал або ролі, на які поширюються процедури ідентифікації та автентифікації Визначено посадову особу, яка управляє політикою та процедурами ідентифікації та автентифікації Визначено частоту, з якою переглядається та оновлюється поточна політика ідентифікації та автентифікації Визначено події, які потребують перегляду та оновлення поточної політики ідентифікації та автентифікації Визначено частоту, з якою переглядаються та оновлюються поточні процедури ідентифікації та автентифікації Визначено події, які потребують перегляду та оновлення процедур ідентифікації та автентифікації	IA-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику реагування на інциденти Політика реагування на інциденти поширюється серед персоналу або ролей Розроблені та задокументовані процедури реагування на інциденти, що сприяють впровадженню політики реагування на інциденти та пов'язаних з нею заходів захисту з реагування на інциденти Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур реагування на інциденти; IR-01(c)[01][01] переглядається та оновлюється поточна політика реагування на інциденти частота; IR-01(c)[01][02] поточна політика реагування на інциденти переглядається та оновлюється після подій; IR-01(c)[02][01] переглядаються та оновлюються поточні процедури реагування на інциденти частота; IR-01(c)[02][02] поточні процедури реагування на інциденти переглядаються та оновлюються після подій Визначено персонал або ролі, до яких має бути доведена політика реагування на інциденти Визначено персонал або ролі, до яких мають бути доведені процедури реагування на інциденти Визначено посадову особу, яка керуватиме політикою та процедурами реагування на інциденти Визначено частоту, з якою переглядається та оновлюється поточна політика реагування на інциденти Визначаються події, які потребують перегляду та оновлення поточної політики реагування на інциденти Визначено частоту, з якою переглядаються та оновлюються поточні процедури реагування на інциденти Визначено події, які потребують перегляду та оновлення процедур реагування на інциденти	IR-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику технічного обслуговування Політика технічного обслуговування поширюється на персонал або ролі Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(с)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(с)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(с)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(с)[02][02] переглядаються та оновлюються поточні процедури технічного обслуговування після подій Визначено персонал або ролі, на які поширюється політика технічного обслуговування Визначено персонал або ролі, на які поширюються процедури технічного обслуговування Визначено посадову особу, яка керуватиме політикою та процедурами технічного обслуговування Визначено частоту, з якою переглядається та оновлюється поточна політика технічного обслуговування Визначено події, які потребують перегляду та оновлення поточної політики технічного обслуговування Визначено частоту, з якою переглядаються та оновлюються поточні процедури технічного обслуговування Визначено події, які потребують перегляду та оновлення процедур технічного обслуговування	МА-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику захисту носіїв інформації Політика захисту носіїв інформації поширюється на персонал або ролі Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. МР-01(с)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; МР-01(с)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; МР-01(с)[02][01] переглядаються та оновлюються поточні процедури захисту носіїв інформації частота; МР-01(с)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації Визначено персонал або ролі, серед яких мають бути поширені процедури захисту носіїв інформації Визначено посадову особу, яка керуватиме політикою та процедурами захисту носіїв інформації Визначено частоту, з якою переглядається та оновлюється поточна політика захисту носіїв інформації Визначено події, які потребують перегляду та оновлення чинної політики захисту носіїв інформації Визначено частоту, з якою переглядаються та оновлюються чинні процедури захисту носіїв інформації Визначено події, які потребують перегляду та оновлення процедур захисту носіїв інформації	МР-1	default_deny_rule, abac_rule_1 admin, security_officer default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; PE-01(c)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; PE-01(c)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; PE-01(c)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. PE-01(c)[02][02] Визначено персонал або ролі, до яких має бути доведена політика фізичного захисту та захисту робочого середовища Визначено персонал або ролі, на які поширюються процедури фізичного захисту та захисту робочого середовища Визначено посадову особу, яка керуватиме політикою та процедурами фізичного захисту та захисту робочого середовища Визначено частоту, з якою переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища Визначено події, які потребують перегляду та оновлення поточної політики фізичного захисту та захисту робочого середовища Визначено частоту, з якою переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища Визначено події, які потребують перегляду та оновлення процедур фізичного захисту та захисту робочого середовища	PE-1	default_deny_rule, abac_rule_1 admin, security_officer admin, security_officer admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30 login, logout, failed_attempt
		Визначено персонал або ролі, до яких має бути доведена політика планування безпеки Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки Визначено періодичність перегляду та оновлення поточної політики планування безпеки Є події, які потребують перегляду та оновлення поточної політики планування безпеки Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки	PL-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Визначено персонал або ролі, на які поширюється політика кадрової безпеки Визначено персонал або ролі, на які поширюються процедури кадрової безпеки Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки	PS-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 щорічно
		Визначено персонал або ролі, на які поширюється політика оцінювання ризику Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику Визначено періодичність перегляду поточних процедур оцінювання ризику	RA-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 щорічно
		Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг	SA-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30
		Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку	SC-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
		Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації	SI-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 30
		Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання	SR-1	admin, security_officer admin, security_officer admin, security_officer default_deny_rule, abac_rule_1 default_deny_rule, abac_rule_1 щорічно
ПЛАНУВАННЯ (PL)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
90	ПЛАН ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)	Призначені особи або групи, з якими пов'язана діяльність з безпекою та конфіденційністю, що впливає на систему, яка потребує планування та координації Призначено персонал або ролі для отримання розповсюджуваних копій планів захисту інформації та конфіденційності системи Визначено періодичність перегляду інформації та конфіденційності системи; планів захисту PL-02a.01[01] розроблено план захисту інформації, архітектурі підприємства організації; який відповідає PL-02a.01[02] розроблено план конфіденційності для системи, відповідає архітектурі підприємства організації; який PL-02a.02[01] розроблено план захисту інформації, який чітко визначає складові компоненти системи; PL-02a.02[02] розроблено для системи план забезпечення конфіденційності, який чітко визначає складові компоненти системи; PL-02a.03[01] розроблено план захисту інформації системи, який описує операційний контекст системи з точки зору місії та бізнеспроцесів; PL-02a.03[02] розроблено для системи план забезпечення конфіденційності, який описує операційний контекст системи з точки зору місії та бізнес-процесів; PL-02a.04[01] розроблено план захисту інформації, який визначає осіб, що виконують системні ролі та обов'язки; PL-02a.04[02] розроблено для системи план забезпечення конфіденційності, який визначає осіб, що виконують ролі та обов'язки в системі; PL-02a.05[01] розроблено план захисту інформації, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.05[02] розроблено план конфіденційності для системи, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.06[01] розроблено план захисту інформації, який передбачає категоризацію безпеки системи, включаючи відповідне обґрунтування; PL-02a.06[02] розроблено для системи план забезпечення конфіденційності, який передбачає категоризацію системи за рівнем безпеки, включаючи обґрунтування; PL-02a.07[01] розроблено план захисту інформації, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.07[02] розроблено план конфіденційності для системи, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.08[01] розроблено план захисту інформації, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.08[02] розроблено для системи план забезпечення конфіденційності, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.09[01] розроблено план захисту інформації, який описує операційне середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.09[02] розроблено для системи план забезпечення конфіденційності, який описує робоче середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.10[01] розроблено план захисту інформації, який містить огляд вимог до	PL-2	admin, security_officer admin, security_officer admin, security_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
91	ПРАВИЛА ПОВЕДІНКИ (PL-4)	Визначено періодичність перегляду та оновлення правил поведінки Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА:{частота; коли правила переглядаються або оновлюються} Визначена періодичність перегляду та повторного підтвердження правил поведінки (якщо вибрано); PL-04a.[01] встановлені правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності для осіб, яким потрібен доступ до системи; PL-04a.[02] надаються правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності, особам, які отримують доступ до системи; PL-04b. отримано перед наданням доступу до інформації та системи задокументоване підтвердження від таких осіб про те, що вони прочитали, зрозуміли та згодні дотримуватися правил поведінки; PL-04c. переглядаються та оновлюються правила поведінки частота; PL-04d. потрібно особам, які визнали попередню версію правил поведінки, прочитати та повторно визнати ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА(iv)	PL-4	щорічно default_deny_rule, abac_rule_1 admin, security_officer
ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA)				
92	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)		SA-8	
93	КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)		SA-22	
94	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)	Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг	SA-9	автоматизований засіб моніторингу admin, security_officer
УПРАВЛІННЯ РИЗИКАМИ В ЛАНЦЮГУ ПОСТАЧАННЯ (SR)				
95	ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)		SR-2	
96	СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)		SR-5	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
97	КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)	Визначено персонал ланцюга поставок, з яким необхідно координувати процес або процеси виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання Визначені засоби контролю ланцюга постачання, що застосовуються для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та конфіденційності; план управління ризиками ланцюга постачання; документ}; SR-03_ODP[05] визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів) Визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів)	SR-3	admin, security_officer автоматизований засіб моніторингу admin, security_officer admin, security_officer